

GRC101

INTRODUCTION TO GRC ENGINEERING

Week 2: ASSIGNMENT

Theory-Based Analytical Assignment

From concepts to integrated GRC capability

Full Name	Adebukola Olanipekun
Registration Number	C11/26/CGRCE/17603
Email Address	bukolufemi@gmail.com
Cohort / Batch	11
Date Submitted	19TH JULY, 2026

PART A - FOUNDATIONS OF INTEGRATED GRC

1. GRC as One Integrated Capability

Explain governance, risk and compliance in your own words. Then analyse why treating them as separate departments can create duplication, conflicting ownership and control gaps. Use one realistic business-unit example to show how an integrated approach produces a better outcome.

RESPONSE

Governance is the system of decision rights, accountability and oversight that directs an organisation toward its objectives; who decides what, who is answerable, and how performance and conduct are monitored.

Risk management is the discipline of identifying, assessing and responding to uncertainty that could affect those objectives, whether threats or opportunities.

Compliance is the function of ensuring the organisation meets its legal, regulatory, contractual and internal policy obligations. Individually, each answers a different question: governance asks "who decides and are they accountable?", risk asks "what could go wrong (or right) and how do we respond?", and compliance asks "are we meeting the rules we're bound by?"

When these three are run as separate departments with separate reporting lines, tools and risk registers, several problems emerge.

A **Duplication:** the same control (say, a vendor due-diligence check) gets assessed independently by internal audit, the risk team and compliance, each requesting similar evidence from the business, wasting time and frustrating staff.

B **Conflicting ownership:** a control might be "owned" on paper by compliance but operationally managed by risk, so when it fails no one is clearly accountable, and governance forums receive contradictory status reports.

C **Control gaps:** because each function scopes its own universe of risks/obligations, issues that sit at the boundary, not clearly a "compliance" rule or a "risk" event fall through the cracks entirely.

Example: Customer Onboarding Unit at Veend HQ

- **Objective:** The onboarding unit at Veend HQ aims to onboard new digital customers within 10 minutes to drive growth in active accounts.
- **Risk:** Faster, lighter-touch onboarding increases the risk of accounts being opened using synthetic or stolen identities (identity fraud risk).

- **Compliance obligation:** Know Your Customer (KYC) and Anti-Money-Laundering (AML) regulations require Veend HQ to verify customer identity documentation before an account can be activated.
- **Governance decision:** Veend HQ's business-unit steering committee, briefed jointly by risk's fraud-likelihood assessment and compliance's regulatory interpretation, decides to approve a tiered onboarding model, full 10-minute processing for low-risk profiles, with automatic escalation to enhanced verification for flagged profiles and assigns clear accountability to the Head of Onboarding for both speed and control performance.

Under a siloed model at Veend HQ, risk might independently recommend slowing all onboarding, compliance might separately draft a stricter KYC policy, and governance might approve a growth target unaware of either, producing contradictory pressures on the business unit. Integrated GRC instead feeds a single risk-and-obligation picture into one governance decision, so Veend HQ's onboarding unit gets a workable control that satisfies regulators, manages fraud exposure, and still supports the growth objective. One decision, one accountable owner, no gaps.

2. The OCEG Capability Model

A business unit plans to launch a new cloud-hosted customer portal. Apply the four OCEG phases Learn, Align, Perform and Review to the launch. For each phase, state the key questions management should ask, the artefacts that should be produced and the responsible role.

RESPONSE

The OCEG Capability Model Applied to a Cloud-Hosted Customer Portal Launch

The OCEG ("GRC Capability") Model breaks integrated GRC into four phases :- Learn, Align, Perform, Review , that operate as a continuous cycle rather than a one-off project. Applied to a business unit launching a new cloud-hosted customer portal, each phase has distinct questions, outputs and owners.

Phase	Key Questions Management Should Ask	Artefacts Produced	Responsible Role
Learn	What are our objectives for the portal (customer self-service, cost reduction)? What is our external context (cloud security regulations, data residency laws, competitor benchmarks)? What is our internal context (existing IT architecture, data classification policy, past incidents)? Who are our stakeholders and what do they expect?	Context and stakeholder analysis report; regulatory/legal obligations register (e.g. data protection law, cloud outsourcing guidelines); objectives statement	Business Unit Head / GRC Analyst (with input from Legal and IT Security)
Align	What risks does this objective introduce (data breach, vendor lock-in, service downtime)? What controls and policies must be designed to address them? Who owns each risk and control? Does the design align with the risk appetite set by the board?	Risk assessment and risk appetite statement; control framework/design document; RACI matrix; cloud vendor due-diligence checklist	Chief Risk Officer / Compliance Officer, ratified by Steering Committee
Perform	Are the agreed controls actually implemented (encryption, access controls, incident response plan)? Is the vendor contract compliant with data protection and cloud outsourcing requirements? Are staff trained on the new processes? Is performance being monitored in real time?	Implemented control evidence (configuration logs, access control lists); signed vendor contract with compliance clauses; training completion records; monitoring dashboard	Portal Project Manager / IT Operations, overseen by Risk Owner
Review	Did the portal launch meet its objectives and stay within risk appetite? Were there control failures, near-misses or audit findings? What did monitoring and incident data reveal? What should change before the next initiative?	Post-launch audit report; incident/exception log; performance-versus-objective scorecard; lessons-learned register	Internal Audit / GRC Committee, reporting to the Board

Feedback loop: Review informing the next Learn cycle

Suppose the Review phase reveals that the cloud vendor experienced two unplanned outages and that customer data residency requirements changed mid-launch (a new regulation now requires in-region data storage). This finding does not stay filed in an audit report, it becomes an input into the next Learn phase, updating the organisation's context analysis and obligations register.

Management then re-asks the Learn-phase questions with this new information: "Does our current vendor still meet regulatory and reliability expectations? Has our risk context changed?"

This drives a fresh Align phase and can be mandating a multi-region hosting clause or a stricter SLA, which is then implemented in Perform and tested again in Review. This closed loop is what makes GRC a continuous capability rather than a one-time compliance exercise: each cycle of Veend HQ's portal governance is informed by evidence from the last.

3. The Three Lines and Accountability

A control failure allowed a former employee's account to remain active for 45 days after departure. Compare the responsibilities of the first line, second line and third line before, during and after the failure. Explain who owns the risk, who provides oversight and who provides independent assurance.

RESPONSE

The Three Lines Model separates risk-taking, risk oversight and independent assurance so that no single function is left checking its own work. The first line (business/IT operations) owns and manages risk day-to-day; the second line (risk and compliance functions) sets policy and provides oversight/challenge; the third line (internal audit) provides independent assurance to the board that the first two lines are actually working. Applied to a former employee's account remaining active for 45 days, each line has distinct, and in this case, failed responsibilities.

Before the failure (design and prevention)

- First line:- HR and IT Operations own the risk: HR is responsible for triggering the offboarding process on the employee's last working day, and IT Operations owns the control of deactivating system access. This is where the risk actually lives, in the operational handoff between HR and IT.

- Second line:- Information Security/Compliance should have designed and mandated a joiner-mover-leaver (JML) policy with a defined SLA (e.g. access revoked within 24 hours) and should periodically test that HR-to-IT handoffs are working, providing oversight of the first line's control design.
- Third line:- Internal Audit should have previously tested the JML process as part of its access-control audit cycle, providing independent assurance to the board that the control existed and was operating, this is the safety net that should have caught a weak handoff before it caused harm.

During the failure (the 45-day window)

- First line: HR failed to notify IT promptly, or IT failed to act on the notification , the operational control broke down at the point where the risk is actually owned.
- Second line: No timely detective control (e.g. automated review of active accounts against HR's leaver list) flagged the discrepancy, meaning oversight monitoring, not just policy-setting also failed.
- Third line: Assurance is inherently retrospective; audit would not detect an in-progress failure unless a real-time whistleblowing or exception report existed, which highlights why detective controls sit with the second line, not the third.

After the failure (detection and remediation)

- First line must now investigate what the dormant account accessed and remediate immediately (deactivate, reset credentials, check logs).
- The second line must assess the root cause, update the JML policy/SLA, and report the incident and control gap to the risk committee, this is oversight translating into corrective policy.
- Third line conducts an independent post-incident review, tests whether the fix actually closes the gap, and reports findings to the audit committee/board, this is assurance validating that lines one and two have genuinely fixed the problem, not just documented it.

Two governance improvements to prevent blurred accountability

1. Assign a single accountable owner for the end-to-end JML process (rather than splitting HR-initiates/IT-executes with no named owner of the handoff itself), with the control formally documented in a RACI so second-line oversight has a clear point of escalation when the SLA is breached.
2. Implement an automated, second-line-owned detective control, a recurring reconciliation of active directory accounts against HR's live employee list so that gaps are caught within days rather than relying solely on a first-line manual handoff and a third-line audit that may only occur annually.

PART B - FRAMEWORK ANALYSIS AND SYNTHESIS

4. Framework Comparison Matrix

Complete a comparative analysis of the five frameworks or regulations below: ISO 31000, COBIT 2019, ISO/IEC 27001, NIST Cybersecurity Framework 2.0 and the Nigeria Data Protection Act 2023. Your matrix must show how each contributes to an integrated GRC capability.

RESPONSE

Here's the matrix and synthesis formatted for clean paste into Google Docs (Google Docs auto-converts markdown tables like this into real tables when pasted in, or you can paste as plain text and use Format > Table if it doesn't auto-convert):

Framework Comparison Matrix

Framework/ Regulation	Primary Purpose	Scope	Principal Users	Key Outputs/ Artefacts	Business-Unit Application	Strongest OCEG Phase(s)
ISO 31000	Provides generic principles and guidelines for managing risk of any type across the enterprise	Enterprise-wide; not industry- or risk-type-specific	Risk managers, executive leadership, boards	Risk management policy, risk framework document, risk register, risk appetite statement	Guides a business unit in identifying and evaluating risks tied to any new initiative (e.g. entering a new market) before controls are designed	Learn and Align: strongest at framing context and shaping risk-informed decisions

COBIT 2019	Governs and manages enterprise IT to ensure IT delivers value while managing IT-related risk	IT governance and management across the whole enterprise	IT governance boards, CIOs, IT risk/compliance officers	Governance/management objectives, capability assessments, process maturity scorecards	Helps a business unit align an IT project (e.g. a new system rollout) with enterprise governance objectives and performance metrics	Align and Review : strong at linking IT decisions to governance objectives and measuring performance
ISO/IEC 27001	Establishes requirements for an Information Security Management System (ISMS) to protect information assets	Information security specifically, certifiable and auditable	InfoSec managers, IT security teams, certification auditors	Statement of Applicability, ISMS policy, risk treatment plan, certification audit report	Gives a business unit a certifiable set of controls (access control, encryption, incident management) to protect customer or operational data	Perform and Review: strongest at implementing controls and undergoing certification audits
NIST Cybersecurity Framework 2.0	Provides a flexible, outcomes-based framework to identify, protect, detect, respond to and recover from cyber risk, plus govern	Cybersecurity risk management, applicable across sectors	CISOs, security operations, risk committees	Current/target profiles, tiering assessment, cybersecurity risk register, governance function outputs (new in 2.0)	Helps a business unit benchmark its cyber maturity and prioritize investment (e.g. detection capability for a new digital channel)	Learn, Perform and Review: spans context-setting through to continuous improvement, now including Govern

Nigeria Data Protection Act (NDPA) 2023	Legally mandates protection of personal data and defines obligations for data controllers/processors	Data privacy and protection, jurisdiction-specific (Nigeria)	Data Protection Officers, Legal/Compliance, business units processing personal data	Data Protection Impact Assessments (DPIAs), data processing register, breach notification records, compliance audit reports (via NDPC)	Sets the legal baseline a business unit must meet when handling customer personal data (e.g. consent capture, breach notification timelines)	Align and Perform : strongest at translating a hard legal obligation into mandatory operational controls
---	--	--	---	--	--	--

Synthesis: Why No Single Framework Is Sufficient

No single framework covers the full breadth of what an integrated GRC capability requires, because each was built to answer a different question. ISO 31000 explains how to think about risk in principle but prescribes no specific controls. COBIT 2019 governs IT decision-making and value delivery but is not a security or privacy standard. ISO/IEC 27001 provides a certifiable, auditable security control set, but it addresses information security specifically, not broader enterprise or legal risk. NIST CSF 2.0 offers a flexible, outcomes-based lens for cyber resilience across five (now six, with Govern) functions, but it is voluntary guidance, not law, and doesn't address non-cyber obligations. The NDPA 2023 is the odd one out in kind: it is a binding legal obligation, not a voluntary best-practice framework, and non-compliance carries statutory penalties regardless of how mature an organisation's ISO or NIST posture is.

Used alone, any one of these leaves gaps: an organisation certified to ISO 27001 could still breach the NDPA if its consent and breach-notification processes are inadequate; a business unit that follows COBIT for IT governance could still suffer a cyber incident if it hasn't operationalised NIST's detect/respond functions. Integrated GRC treats these frameworks as complementary layers , ISO 31000 for risk philosophy, COBIT for IT governance, ISO 27001 and NIST for security control and maturity, and NDPA as the non-negotiable legal floor ,mapped together so that Learn, Align, Perform and Review draw on all of them at once rather than any single source of truth.

5. From Many Frameworks to One Common Control Framework

Explain the purpose of a Common Control Framework (CCF). Then design a small framework-mapping example for the enterprise control “Privileged Access Management”. Map the control to at least four relevant sources from the course, such as ISO/IEC 27001, NIST CSF 2.0, NIST SP 800-53, NDPA 2023, PCI DSS or COBIT 2019.

RESPONSE

From Many Frameworks to One Common Control Framework

Purpose of a Common Control Framework (CCF)

A Common Control Framework is a single, internally-owned set of controls built by mapping and rationalizing the overlapping requirements of multiple external frameworks and regulations into one control library. Rather than a business unit maintaining separate control sets for ISO 27001, NIST, PCI DSS and local data protection law — each with its own evidence requests, testing cycles and owners , a CCF identifies where these requirements converge on the same underlying control activity, defines that control once, and maps it back to every source obligation it satisfies. The purpose is to reduce duplication, give the organisation one point of accountability per control, and let audit/compliance teams demonstrate multi-framework coverage from a single body of evidence, rather than re-proving the same control five different ways for five different auditors.

Framework-Mapping Example:

Privileged Access Management (PAM)

Control objective: Ensure that privileged (administrative/elevated) access to critical systems is granted only to authorized personnel, on a least-privilege basis, and is actively monitored to prevent misuse or unauthorized access.

Control owner: Head of Identity and Access Management (IAM)

Source Framework	Relevant Requirement Mapped to PAM
ISO/IEC 27001	Annex A control on access rights management and restriction of access to information and system functions, requiring formal user access provisioning and periodic review of privileged rights
NIST CSF 2.0	Protect function : Identity Management and Access Control category, requiring that access permissions and authorizations be managed incorporating least privilege
NIST SP 800-53	Access Control (AC) family, specifically controls on least privilege and privileged account management, requiring restriction and auditing of privileged functions
NDPA 2023	Requirement that data controllers/processors implement appropriate technical and organizational measures to prevent unauthorized access to personal data, which privileged accounts are capable of accessing
PCI DSS	Requirement restricting access to cardholder data on a need-to-know basis and assigning unique IDs with monitored access for all privileged users
COBIT 2019	Management objective covering managed security services, including governance over identity and access management as an IT control domain

Evidence items (three):

1. Privileged access request and approval logs (showing who approved elevated access and why)
2. Quarterly access recertification report (showing periodic review and removal of unneeded privileged rights)
3. Privileged session monitoring/audit logs (showing that privileged sessions are logged and reviewed for anomalous activity)

Control-testing procedures (two):

1. Sample-based testing: Select a sample of privileged accounts from the access management system and trace each back to an approved access request, verifying that access was authorized, is still required, and matches the individual's current role.
2. Re-performance/observation testing: Observe or reperform the quarterly recertification process to confirm that access reviews are actually being conducted as scheduled, that flagged excess access is revoked within the defined SLA, and that session monitoring alerts are being actioned rather than just logged.

How One Control Satisfies Multiple Obligations While Still Requiring Framework-Specific Interpretation

A single, well-designed Privileged Access Management control can be mapped to ISO 27001, NIST CSF, NIST SP 800-53, NDPA, PCI DSS and COBIT simultaneously because all six sources are, at their core, asking the same underlying question: is access to sensitive systems and data restricted to those who need it, and is that access monitored? Implementing one robust PAM process, with formal approval, least-privilege provisioning, periodic recertification and session monitoring, therefore generates evidence that can be reused across every applicable audit or assessment, rather than the organisation running six parallel, near-identical control implementations.

However, reuse of the control does not mean the obligations are identical in substance. Each framework layers its own specific interpretation on top of the same control activity. PCI DSS, for example, cares specifically about access to cardholder data environments and expects unique IDs and monitoring tied to that scope. The NDPA cares about access to personal data of Nigerian data subjects and requires the organisation to demonstrate "appropriate technical and organizational measures" specifically in a data-protection context, potentially triggering breach-notification obligations if privileged access is misused. NIST SP 800-53 expects the control to be tied to a documented system security plan with specific control enhancements, while ISO 27001 expects it to sit within a certified ISMS with a Statement of Applicability justifying its inclusion. So while the control activity is common, the control owner must still tailor documentation, testing evidence and reporting language to each framework's specific vocabulary, scope and audit expectations, the CCF gives efficiency of design, not a license to ignore each source's particular lens.

PART C - APPLIED ESSAY

6. "GRC Succeeds or Fails in the Business Unit"

Write an analytical essay on the statement: "Policy is written at the centre, but risk is taken and controls are performed at the edge." Discuss the role of business-unit management, culture, incentives, risk registers, control ownership, escalation, evidence and management review. Use examples from at least three framework families covered in the course.

RESPONSE

GRC Succeeds or Fails in the Business Unit

"Policy is written at the centre, but risk is taken and controls are performed at the edge."

Introduction

Governance frameworks, risk registers and control catalogues are almost always authored centrally, by a risk function, a compliance team, or a group-level policy office sitting several layers removed from daily operations. Yet the moment of truth for any GRC programme never happens at the centre. It happens at the edge: in the business unit where a loan officer decides whether to override an exception, where an onboarding agent decides whether to escalate a flagged customer, or where an IT administrator decides whether to grant privileged access under time pressure. A central policy document does not, by itself, prevent a control failure; a business-unit employee acting consistently with that policy does. This essay argues that GRC succeeds or fails not at the point of design but at the point of daily execution, and examines the organisational levers, culture, incentives, ownership, escalation and evidence that determine which outcome prevails.

The Gap Between Centre and Edge

Centrally written policy is, by necessity, generic. ISO 31000 instructs organisations to embed risk management "into all organizational activities," but it cannot specify what a particular branch manager should do when a long-standing customer requests an unusual transaction. NIST CSF 2.0 requires that access permissions be managed on a least-privilege basis, but it cannot anticipate every operational trade-off between security and speed that a business unit faces on a Tuesday afternoon. COBIT 2019 governs IT value delivery at an enterprise level, but the actual "moment of risk", a system administrator granting an exception, a developer pushing an untested change occurs entirely within the business unit's operational rhythm. This is the structural reason policy alone is insufficient: policy describes intent, but the edge is where intent meets pressure, ambiguity and competing priorities.

Business-Unit Management as the Real Control Owner

The most important determinant of whether policy translates into practice is business-unit management itself. Central risk and compliance functions can design a control, but they do not perform it, they depend entirely on business-unit leadership to operationalise it correctly, day after day, without direct supervision. This is why frameworks increasingly insist on named control ownership rather than departmental ownership. NIST SP 800-53's access control family, for instance, is only effective if a specific accountable individual, not "IT" in the abstract owns the privileged access review cycle and is measured on whether it actually happens. When ownership is diffuse ("everyone is responsible for security"), it becomes no one's job in practice, and this is precisely where control gaps emerge not because the policy was wrong, but because no one at the edge felt personally accountable for executing it.

Culture and Incentives: The Invisible Control Environment

Even with clear ownership, culture and incentives shape whether a control is genuinely performed or merely documented. A business unit incentivised purely on speed-to-revenue for example, an onboarding team measured only on accounts opened per day will rationally deprioritise a control that slows them down, regardless of what the risk register says. This is the tension implicit in NDPA 2023-style obligations: a data protection impact assessment is a paper exercise unless business-unit culture treats data minimisation as a genuine value rather than a legal formality imposed from outside. Where incentives and controls point in opposite directions, incentives win, because incentives are felt daily and controls are audited periodically. A mature GRC culture therefore requires that performance metrics for business-unit staff explicitly include control performance, not just commercial output, otherwise the "edge" is structurally set up to erode whatever the "centre" is designed.

Risk Registers That Live, Not Registers That Sit

Risk registers are frequently treated as centrally-maintained compliance artefacts, updated quarterly and largely disconnected from daily decision-making. For a risk register to matter at the edge, business-unit management must treat it as a working tool, reviewed when a new product launches, updated when a near-miss occurs, and referenced when prioritising remediation. ISO 31000's risk management process is only as good as the frequency and honesty with which the business unit updates its likelihood and impact assessments in light of real operational experience, rather than treating the register as a static document produced to satisfy an annual audit.

Escalation, Evidence and Management Review

Escalation pathways determine whether an edge-level problem reaches someone with authority to fix it before it becomes a control failure. In the earlier case of a dormant employee account remaining active for 45 days, the absence of a working escalation trigger, no automated alert, no clear point of contact when HR's handoff to IT stalled, meant the risk sat undetected for weeks. Evidence is what allows both business-unit management and

independent assurance functions to verify that controls are operating as designed rather than merely believed to be operating; PCI DSS's emphasis on access logs and unique user IDs exists precisely because "we trust our staff" is not evidence. Finally, management review, a business-unit leader periodically and genuinely examining control performance, not simply signing off a compliance attestation, is the mechanism that closes the loop between the edge's daily reality and the centre's assumption that policy is working.

Conclusion: Five Actions for the Next 90 Days

For a business-unit leader who accepts that GRC succeeds or fails at the edge, the following five actions provide a practical starting point:

1. Name a single accountable owner for each of the unit's top five controls (not a department), and confirm each owner understands their responsibility within the next two weeks.
2. Review incentive structures for frontline staff to ensure control performance (not just output or speed metrics) is explicitly part of how success is measured and rewarded.
3. Conduct a live walkthrough of the unit's risk register with operational staff, not just risk/compliance to confirm it reflects real current risks rather than outdated, centrally-imposed entries.
4. Test the escalation path for at least one critical control (e.g. simulate a delayed offboarding or an access anomaly) to confirm that alerts actually reach someone empowered to act within a defined timeframe.
5. Schedule a genuine management review session within the quarter, reviewing actual evidence (logs, exception reports, testing results) rather than a compliance checklist, and use findings to update both the risk register and control design, closing the loop between edge performance and centre policy.